

This binder prepares you for every question Olivia is likely to ask.

For each question: (1) What the technical reality is. (2) What it means in plain English. (3) What to say on the call. (4) What follow-ups she may ask. (5) What risks to be honest about.

How to use this binder

CTO Call Preparation Binder

Everything in here is sourced from the repository. No speculation. No marketing language. If it's not in the code, docs, or test output, it is not in this document.

Line Axia — Olivia Aréchiga

CONTENTS

- Prepared for: Jesse Lamont, Founder, Lamont Labs
- Repository: CerbaSeal Core (v0.2.0) Date: 2026-06-02
- Section 1 — Where is CerbaSeal right now? (The VeraSeal question)
- Section 2 — Can this be deployed in a client-controlled or EU environment?
- Section 3 — What does your operational role look like during a pilot?
- Section 4 — What is your realistic capacity for a pilot engagement?
- Section 5 — Open-source components and third-party dependencies
- Section 6 — 25 most likely follow-up questions — with answers
- Section 7 — Founder Cheat Sheet — one page, plain English

Olivia's Question: "Where is CerbaSeal relative to external deployment, specifically VeraSeal as the first component? What does pilot-ready mean and what is the gap?"

CRITICAL: What Is VeraSeal?

VeraSeal Does Not Exist In The Repository

"VeraSeal" does not appear anywhere in this repository — not in any file name, source code, test, documentation, or comment. There is no component, module, or system called VeraSeal. If Olivia asks about VeraSeal on the call, she has gotten the name from somewhere else. Correct it immediately and move on. Do not improvise a definition.

The enforcement core is called CerbaSeal — specifically a module called ExecutionGateService inside the src/services/execution/ folder. That is the only enforcement system in this repository.

What Is CerbaSeal? (Plain English)

CerbaSeal is a gatekeeper. When an AI-assisted system wants to take an action — send a payment, approve a transaction, execute a process — CerbaSeal sits in between and answers one question: "Should this be allowed to happen right now?" It looks at who is asking, whether the right approvals are in place, and whether the request meets a set of rules. Then it issues a verdict: ALLOW (go ahead), HOLD (wait for approval), or REJECT (blocked).

Every verdict is logged with evidence — a record of what was checked, what the outcome was, and why. That record cannot be altered after the fact.

What Is Currently Built and Working

The Enforcement Core — IMPLEMENTED

- 12 rules (called invariants) that every request must pass before ALLOW is issued
- Three possible outcomes: ALLOW, HOLD, or REJECT — nothing else
- Fail-closed behavior: if anything unexpected happens, the system blocks, not permits
- AI cannot authorize its own requests — this is a hard rule, not a setting
- Evidence bundle created for every decision — a verifiable record of what happened and why
- Hash-linked audit trail — each entry is mathematically connected to the one before it, so deletions are detectable
- Replay verification — any decision can be re-examined and confirmed as consistent
- Diagnostic reports — when something is blocked, the system explains exactly which rule was triggered and why

The Test Suite — IMPLEMENTED

- 372 tests passing, 0 failing, across 15 test files
- 66 adversarial tests specifically designed to try to break or bypass the enforcement
- 27 misuse scenario tests based on real-world AI governance failure patterns
- 25 contextual boundary tests probing edge cases
- 15/15 audit checks passing (an independent automated verification of the whole system)

The Review Portal — IMPLEMENTED

- Live browser portal at cerbaseal.replit.app — technical reviewers can see the system running
- 4 portal pages: review, pilot readiness, security controls, deployment posture
- All portal claims are tested — if a claim disappears from a page, a test fails

What Is Demo-Only (Not Client-Ready)

Demo Infrastructure

The live site at cerbaseal.replit.app runs on Replit's servers. This is appropriate for Olivia to look at and test. It is not appropriate for real client data or production decisions. It is a demonstration, not a deployment.

What Is NOT Implemented

- Persistent storage — the audit log exists only in memory and is lost when the server restarts
- Cryptographic signing — the evidence chain is mathematically consistent but not key-signed or legally attested
- EU deployment — no deployment outside Replit has ever been executed
- Client-specific workflow — no client's actual workflow has been configured yet
- Third-party security review — all security review to date has been internal
- Production hardening — no container, no deployment runbook, no infrastructure configuration
- Signed commercial agreement with any client — none exists

What Did VeraSeal / Cerba / Other Lamont Labs Systems Contribute?

No Evidence of These Systems

"VeraSeal" does not appear anywhere in this repository. "Cerba" as a standalone system does not appear. There are no references to other Lamont Labs products contributing to this codebase. If asked, the honest answer is: "Everything in this repository is CerbaSeal, built from scratch. I don't have a separate component called VeraSeal." Do not improvise.

What "Pilot-Ready" Actually Means

The Correct Definition

Pilot-ready means: one client, one workflow, one controlled environment, no production decisions. It does NOT mean production-ready. It means the enforcement core is solid enough to evaluate in a controlled setting with defined success criteria and a signed agreement in place first.

What needs to exist before a pilot begins

- Signed working agreement covering scope, evidence ownership, liability, and support terms
- Persistent storage solution (audit log must survive server restart)
- Client deployment environment identified and reviewed
- One specific client workflow defined and agreed
- Data processing agreement if EU client data is involved
- Success criteria agreed in writing — what does "governance working" look like?

WHAT TO SAY ON THE CALL (Section 1)

"CerbaSeal is the enforcement core — there isn't a separate component called VeraSeal in this build. What I have today is a working governance engine: 372 tests, 15 independent audit checks, 12 hard rules that every request must pass. The demo you can see running right now is not connected to any client data — it's a demonstration. Pilot-ready to me means one workflow, one client, controlled environment, no production decisions, and a signed agreement before we touch anything real. The main thing I need to build before a pilot is persistent audit storage — so the evidence log survives a server restart. That's a bounded piece of work, not a fundamental gap."

Olivia's Question: "Can CerbaSeal be deployed in a client-controlled or EU-hosted environment?"

The Short Technical Answer

Architecture Supports It

CerbaSeal makes no network calls, has no cloud dependencies, and has no external services of any kind. It runs as a Node.js package. If you can run Node.js in your infrastructure, you can run CerbaSeal. EU hosting is architecturally straightforward. The caveat is that it has never been done yet.

What Has Been Proven

- No outbound network calls in any enforcement code path — confirmed by source code review
- No external API dependencies — confirmed by full dependency audit (1 runtime dep: tsx, MIT licensed)
- No cloud SDK, no authentication provider, no database driver
- Four deployment modes documented: embedded library, internal service, sidecar, air-gapped
- Mode C (client-controlled EU environment) is the documented preferred approach for EU pilots
- Package is deployable wherever Node.js runs — no geographic restriction in the code

What Has NOT Been Proven

- No EU deployment has ever been executed — this would be the first
- No Dockerfile or container configuration exists
- No deployment runbook or step-by-step guide exists
- No infrastructure-as-code (Terraform, Ansible, etc.) exists
- No DPA (Data Processing Agreement) template exists
- No GDPR analysis has been completed
- No legal review of EU jurisdiction requirements has been done

The Four Deployment Options (Plain English)

Option 1 — Embedded

CerbaSeal runs inside the client's own system, at the point where decisions are made. Lowest overhead. Requires the client to have a Node.js application.

Option 2 — Internal Service

CerbaSeal runs as a separate internal service that other systems call. Clean separation. Requires the client to run it on their internal network.

Option 3 — Sidecar

CerbaSeal runs alongside the client's existing system, intercepting decisions before they execute. Good for regulated systems that need a clear audit boundary.

Option 4 — Air-Gapped

CerbaSeal runs completely offline, with no network connection at all. Maximum isolation. Good for highly regulated environments. Manual process.

Data Residency — What This Means For Line Axia

Data residency means: where does your data live, and does it ever leave that location? For an EU-based firm with EU clients, data residency is a legal requirement, not a preference.

CerbaSeal's answer: if you deploy it in your EU infrastructure, your data never leaves. CerbaSeal does not call home. It does not send telemetry. It does not require a connection to anything outside the environment you put it in. The data stays where you put the system.

What Must Still Be Done Before EU Pilot

Even though the architecture supports EU hosting, three things must happen before any real data touches it: (1) A Data Processing Agreement must be signed. (2) The specific EU hosting environment must be reviewed. (3) A legal review of EU evidence retention requirements must be completed. None of these have been done yet. This is an honest gap, not a showstopper.

EU AI Act Relevance

The EU AI Act requires audit trails for high-risk AI systems. CerbaSeal produces an audit trail for every decision. However: the current audit trail is hash-linked for consistency, not cryptographically signed for legal attestation. For EU AI Act compliance, the evidence chain would need HMAC signing or an external attestation service. This is a documented future requirement, not a current implementation.

WHAT TO SAY ON THE CALL (Section 2)

"Yes, the architecture supports EU deployment — there are no external calls, no cloud dependencies, nothing that sends data outside the environment you deploy it in. The preferred pilot approach is Mode C: you control the hosting environment and the data never leaves it. What I want to be honest about: I have not actually deployed CerbaSeal outside Replit yet. The path exists and the architecture is ready for it, but the first EU deployment would be the first deployment anywhere. We would need a DPA in place before touching real data, and I would want the deployment environment reviewed before we go live. Those are prerequisites, not obstacles."

Olivia's Question: "What would your operational role look like during a pilot?"

Week 1 — Scoping (Highest Intensity)

Week 1 is the busiest week. This is where the actual work of setting up the pilot gets done.

- Kickoff call (60 minutes): identify the workflow to govern, define success criteria, agree the authority model
- Deploy CerbaSeal in the agreed pilot environment
- Run baseline tests: confirm REJECT, HOLD, and ALLOW all work as expected in the client's context
- Produce a signed pilot scope document — the contract for what is and isn't covered
- Produce a workflow map, an authority matrix, and a set of baseline test scenarios
- Agree the success metrics in writing — what does "governance working" look like for this workflow?

Ongoing — Weekly Rhythm

- One 30-minute review call per week — agenda: open issues, resolved issues, enforcement metrics
- Email support for questions during the week
- Tracked issue queue — every issue gets an ID, a severity, a status, and resolution notes
- Status update published weekly: what was open, what was resolved, what is deferred
- Decision log maintained: whenever a governance interpretation or scope call is made, it is written down

Issue Response Times (Documented Commitments)

P1 — System Down !' Same business day

The pilot environment is not running or the gate is not producing outcomes.

P2 — Major Impact !' Within 24 hours

The system is doing something that contradicts the documented rules.

P3 — General Issue !' Within 3 business days

Documentation question, configuration question, behavior clarification.

P4 — Enhancement !' Reviewed at weekly planning

Something new that was not in the original scope.

What Happens If You Are Unavailable (Up To 48 Hours)

What Continues Without You

Demo environment, all documentation, security docs, review portal, proof snapshots, invariant registry — all accessible. The system can be re-audited independently: "pnpm audit:repo" re-runs all 15 checks without the founder. "pnpm verify:proof" verifies the snapshot has not been tampered with. Evidence bundles and diagnostic outputs are all human-readable without you.

What Pauses

New issue investigation requiring code changes, configuration changes to the pilot environment, and scheduled review calls (rescheduled on return). Beyond 48 hours: no contingency is documented. This is an honest gap for a solo-founder engagement.

What Is Out Of Scope (Important To State On The Call)

- Custom feature development outside the pilot scope
- Production deployment work (pilot environment only)
- Legal or regulatory compliance opinions
- Integration engineering into Line Axia's internal systems

- Data migration, data modeling, or schema design for production
- Indefinite open-ended support
- Building new workflow classes not defined at kickoff

Changes outside scope become a next phase — defined in a separate agreement.

What Gets Handed Over At Pilot End

- Final findings report: what governance outcomes were observed, what issues came up, how they were resolved
- Governance assessment: did the workflow get governed as agreed?
- Documented gaps: what CerbaSeal does not yet do that production would need
- Recommended next steps: specific and bounded — not a sales pitch
- All evidence bundles produced during the pilot
- Technical summary: architecture decisions, invariants exercised, enforcement metrics

Everything produced during the pilot is the client's. Nothing is withheld.

What Eventually Gets Handed Off

CerbaSeal is designed so the pilot participant does not need the founder for every question. The system explains its own decisions — every blocked action comes with a reason code and a diagnostic report. Eventually: evidence review, audit re-runs, routine configuration questions, and day-to-day governance reading can all be done without founder involvement. Founder presence is highest at week one and decreases over time.

WHAT TO SAY ON THE CALL (Section 3)

"Week one is my most intensive week — that's where we scope the workflow, deploy the system, run the baseline scenarios, and get the agreement signed. After that it's a weekly 30-minute call, email support, and a tracked issue queue. I have documented response times: same business day for a system outage, 24 hours for a rule violation, 3 days for general questions. I am a solo founder and I want to be honest about that — I have documented what happens if I'm unavailable and built the system so you don't need me to interpret every outcome. The system explains itself. What I cannot promise is 24/7 on-call support — that would need a bigger structure, and we should define that in the agreement."

Olivia's Question: "What is your realistic capacity for a pilot engagement?"

No Repository Evidence For This Section

The repository does not contain information about Jesse's personal schedule, current portfolio, or capacity constraints. Everything in this section is structured guidance for how to answer honestly based on what the repository documents as the pilot support model. Jesse fills in the blanks.

What The Pilot Actually Requires From You

Week 1 (Highest Demand)

- Kickoff call: ~1 hour
- Deployment and baseline scenario execution: estimate 4–8 hours depending on client environment complexity
- Producing pilot scope document, workflow map, authority matrix, baseline scenarios: 4–6 hours
- Total week 1 estimate: 10–15 hours of active founder work

Ongoing (Weeks 2 onward)

- 30-minute weekly review call
- Issue queue management: 1–3 hours/week depending on volume
- Email support: varies, but light in a well-scoped pilot
- Total ongoing estimate: 3–5 hours/week in a normal week

Spikes (When Issues Occur)

- P1 issue (system down): could require a half-day to investigate and resolve
- P2 issue (rule violation): could require 2–4 hours of investigation
- These are infrequent in a controlled pilot but must be budgeted

Realistic Constraints To Name On The Call

The right answer here is honest and direct. The repository documents a solo-founder model explicitly. The question is not whether you have capacity — it is whether you have defined it clearly enough that Olivia can plan around it.

- You are a solo founder — no second engineer as a backup
- The 48-hour self-service model is the documented contingency
- Beyond 48 hours unavailability: no formal contingency exists
- Active pilot would be the first external client deployment
- No managed infrastructure exists — you deploy manually for each client

Hardware and Software Needs

- Node.js runtime (standard — most infrastructure already has this)
- tsx 4.21.0 (MIT licensed, installs via npm in seconds)
- No cloud accounts, no paid services, no proprietary tooling required
- Client provides the hosting environment for Mode C deployments
- Founder needs: standard developer laptop, internet connection, email

Supply Chain Simplicity

One runtime dependency (tsx). Five packages total in the deployment. This is genuinely unusual for enterprise governance software and works in your favour when discussing operational complexity.

What Support You Would Likely Need

- Client's IT team to provision the deployment environment (Mode C)

- Client's engineering contact to construct workflow requests in the correct format
- Legal review from client side for DPA and working agreement
- Potentially: a deployment engineer for the first EU deployment if it's complex

WHAT TO SAY ON THE CALL (Section 4)

"Week one is my most demanding week — I estimate 10 to 15 hours of active work to scope, deploy, and baseline the pilot. After that I run at 3 to 5 hours a week in a normal week. I don't have other active pilot deployments right now. I'm a solo founder, and I want to be explicit about what that means: I have defined response times, a documented self-service model, and I have built the system to be readable without me. What I cannot offer is 24/7 on-call support — if that is a requirement, it needs to be part of the engagement structure and priced accordingly."

Olivia's Question: "Are there any open-source components or third-party dependencies in the deployment stack we should be aware of?"

Executive Summary

CerbaSeal has one (1) production runtime dependency: tsx — a TypeScript execution runtime, MIT licensed. All other dependencies exist only at build and test time and are not present in a deployment. No cloud services, no SaaS APIs, no authentication providers, no telemetry, no database drivers. Zero external service calls at runtime.

Runtime Dependencies (Present In Deployment)

tsx 4.21.0 (MIT) — Risk: Low

Runs the TypeScript enforcement code. Think of it as the engine that reads and executes the governance rules.

esbuild 0.27.3 (MIT) — Risk: Low

Used internally by tsx to transform code. Not called directly by CerbaSeal. Only the version matching your server's operating system loads at runtime.

get-tsconfig 4.13.6 (MIT) — Risk: Low

Utility used by tsx to find TypeScript configuration. Not visible to CerbaSeal logic.

resolve-pkg-maps 1.0.0 (MIT) — Risk: Low

Package path resolution utility used by get-tsconfig.

Development-Only Dependencies (NOT In Deployment)

These packages are used to build and test CerbaSeal. They are not deployed to clients and a client security team does not need to review them.

- TypeScript 5.9.3 — the compiler (Apache 2.0)
- Vitest 2.1.9 + test stack — the test framework that runs the 372 tests (MIT)
- pdfkit 0.18.0 — generates PDF reports like this one (MIT)
- @types/node 22.19.17 — TypeScript type definitions for Node.js (MIT)

License Summary

MIT

Majority of all packages. No restrictions on commercial use, no source disclosure required.

Apache 2.0

TypeScript compiler only (dev). No restrictions relevant to this use case.

MPL-2.0

lightningcss — dev/build only, not in deployment. Weak file-scoped copyleft, does not affect CerbaSeal source.

GPL / AGPL / LGPL

NOT PRESENT anywhere in the dependency tree.

Copyleft Determination

The production deployment of CerbaSeal contains ZERO copyleft-licensed software. All runtime licenses are MIT. Nothing requires CerbaSeal source code to be disclosed to clients. GPL is not present anywhere in the tree — runtime or development.

External Services Review

Cloud dependencies: **NONE**

SaaS dependencies: **NONE**
External API calls: **NONE** — confirmed by source code review
Database dependencies: **NONE**
Telemetry / analytics: **NONE**
Authentication providers: **NONE**
CDN dependencies: **NONE**
Outbound network calls: **NONE** — confirmed by source code review

Supply Chain Questions — Direct Answers

Can CerbaSeal run entirely in a client-controlled environment?

Yes. No component requires a Lamont Labs–operated service to function after installation.

Can CerbaSeal run entirely in an EU-hosted environment?

Yes, architecturally. No geographic restrictions in the code. Caveat: not yet executed.

Does CerbaSeal require any US-operated services?

No. npm is used at install time and can be replaced with a private registry or offline bundle.

Does CerbaSeal require internet after deployment?

No. Once installed, all enforcement runs offline. No connectivity needed.

What would a client security review need to approve?

Node.js runtime + tsx + esbuild (platform binary) + get-tsconfig + resolve-pkg-maps + CerbaSeal source. Five packages total.

60-SECOND VERBAL ANSWER FOR OLIVIA (Section 5)

"CerbaSeal has one production dependency — tsx, which is a TypeScript runtime, MIT licensed. That's it. No cloud services, no external APIs, no telemetry, nothing that calls outside your environment. Every enforcement decision runs entirely inside the deployment boundary. All runtime licenses are MIT — no GPL, no copyleft, nothing that requires source disclosure. If your security team needed to review the deployment, the list is Node.js — which you probably already have — tsx, esbuild, and two small utilities. Five packages total."

Q: 1. "Can you show me CerbaSeal running on infrastructure we control — not Replit?"

WHY SHE ASKS: Replit is a developer sandbox, not enterprise infrastructure. Any serious CTO will want to see the system running where it would actually be used.

YOUR ANSWER: "Not yet — the first client deployment has not happened. What I can show you is the full system running on Replit right now, and I can walk you through exactly what a Mode C deployment to your environment would look like. The architecture has no barriers to it. The work is in the first execution, not the design."

AVOID SAYING: Do not imply you have done this before. You have not.

If she follows up:

- "How long would a first deployment take?" — Honest answer: 1–3 days for a controlled pilot environment once we agree on the hosting setup.

Q: 2. "What happens to the evidence log if the server restarts?"

WHY SHE ASKS: Persistent storage is the single most important technical gap. Any CTO reading the security brief will find it. She will ask.

YOUR ANSWER: "Right now, the audit log is in-memory. If the process restarts, the log for that session is gone. This is the highest-priority item on my pre-pilot build list. For a pilot the fix is file-based or database-backed storage — bounded work, not a redesign. This must be in place before any client data touches the system."

AVOID SAYING: Do not minimize this. It is a real gap. Naming it clearly builds more trust than hedging.

If she follows up:

- "How long to fix it?" — Estimate: 2–5 days to implement file or SQLite-backed persistent audit log. Production-grade storage is a separate scoping discussion.

Q: 3. "Who else has reviewed the security of this system?"

WHY SHE ASKS: A governance tool for regulated industries must have external validation. She will assume this is table stakes.

YOUR ANSWER: "No third-party security review has been completed yet. All security review to date is internal. I have a security brief that documents every known limitation honestly — I'd rather you read that than have a false comfort level. An external review is on the roadmap and I would want it before any production use."

AVOID SAYING: Do not imply any third-party validation has occurred. It has not.

If she follows up:

- "Which firm would you use?" — Have a name or type ready: "Likely a boutique security firm specializing in AI governance or financial infrastructure."

Q: 4. "What happens if you're unavailable — hit by a bus, so to speak?"

WHY SHE ASKS: Solo-founder risk is a standard diligence question. She needs to know the engagement can survive your absence.

YOUR ANSWER: "I've documented this. Up to 48 hours: the system is self-contained. Your team can re-run all 15 audit checks independently, verify the proof snapshot, read all evidence output, and access all documentation without me. Beyond 48 hours: I don't have a backup engineer today. That is an honest gap. If the engagement requires a second resource, that becomes part of the structure we agree."

AVOID SAYING: Do not claim you have a backup you don't have.

Q: 5. "What version of CerbaSeal would we be freezing for the pilot, and how do updates work?"

WHY SHE ASKS: Any responsible CTO will want to know they're not signing up for a moving target.

YOUR ANSWER: "We would freeze a specific version at pilot start — version 0.1.0 today, and any later snapshot we agree. The version freeze policy would be defined in the working agreement. Updates during a pilot require a change log entry and your sign-off. No changes to enforcement behavior happen without notice."

AVOID SAYING: Do not imply a formal update/versioning system exists that doesn't.

If she follows up:

- "Is there a software update policy document?" — Not yet. This would be part of the working agreement.

Q: 6. "Can you show me a GDPR analysis for this system?"

WHY SHE ASKS: Line Axia is EU-based with EU clients. GDPR is not optional for them.

YOUR ANSWER: "I don't have a completed GDPR analysis. What I can tell you is the architecture: no data leaves the deployment environment, no external services, no telemetry. Whether the evidence bundles produced during a pilot constitute personal data under GDPR depends on what workflows you run CerbaSeal on. That analysis requires a legal review — and a DPA between us — before we touch real client data."

AVOID SAYING: Do not claim GDPR compliance. You have not done the analysis.

Q: 7. "What does 'policy pack reference' actually mean? Does CerbaSeal evaluate the policy content?"

WHY SHE ASKS: A technically sophisticated reviewer will look at the invariant model and notice that policyPackRef is required but the content is not evaluated. This looks like a gap.

YOUR ANSWER: "CerbaSeal requires a policy pack reference — a pointer to the policy governing the request. It checks that the reference exists. It does not evaluate what's inside the policy document. That evaluation is handled upstream by the client's system. CerbaSeal enforces the governance layer: is there approval, is the actor authorized, is the action known. Policy content interpretation is explicitly out of scope."

AVOID SAYING: Do not imply CerbaSeal reads or interprets policy documents. It does not.

Q: 8. "Do you have cyber liability insurance?"

WHY SHE ASKS: For an enterprise engagement in a regulated sector, this is standard diligence.

YOUR ANSWER: Jesse answers this directly. If you have it, state the coverage. If you do not have it, be honest: "I don't currently have a cyber liability policy. For a production engagement in a regulated sector, that would need to be on the table. It's something I would want to address before a signed production agreement."

AVOID SAYING: Do not bluff on this. Tina Simpson will verify.

Q: 9. "What does the working agreement look like?"

WHY SHE ASKS: If this call goes well, the next thing is a term sheet or agreement. She will want to know you've thought about this.

YOUR ANSWER: "The prerequisites list is documented: scope, evidence ownership, liability boundary, support terms, DPA if applicable, version freeze policy. The two items I'd want to nail down early are: what counts as a change request and what it costs, and who owns the evidence artifacts produced during the pilot. I'd want governing law defined before anything is signed."

AVOID SAYING: Do not promise a draft agreement you don't have ready.

If she follows up:

- "What jurisdiction for governing law?" — Jesse answers this. Know your preference before the call.

Q: 10. "How do we know the audit chain wasn't fabricated?"

WHY SHE ASKS: This is the right question to ask about any governance system. A sophisticated reviewer will ask it.

YOUR ANSWER: "The audit chain uses SHA-256 hash linking — each entry contains the hash of the previous entry. If you delete or alter any entry, the chain breaks and verification fails. What it does not do yet is HMAC signing — meaning a technically sophisticated attacker who controls the whole system could recompute the hashes. For legal-weight evidence, you would need HMAC or external attestation. This is on the documented gap list. For a pilot evaluation context, the hash chain is sufficient to show consistency."

AVOID SAYING: Do not claim cryptographic signing exists. It does not.

Q: 11. "What is your pricing model?"

WHY SHE ASKS: If the technical case holds, she will move to commercial terms.

YOUR ANSWER: Jesse answers this directly. Suggested framing: "I prefer a fixed-fee structure for a bounded pilot — cleaner for both sides. Week one is the highest effort. Ongoing is lighter. Change requests are priced separately. Percentage structures create ambiguity on a v0.1 product and I don't think they serve either of us well at this stage."

AVOID SAYING: Do not give a number you haven't thought through.

Q: 12. "What happens when CerbaSeal encounters a request type it doesn't recognize?"

WHY SHE ASKS: Edge cases and unknown inputs are where governance systems fail most visibly.

YOUR ANSWER: "Unknown action classes trigger a reject with a documented reason code. Unknown inputs at the structural level trigger a fail-closed reject. The system does not guess or default to allow. If it cannot categorize the request, it blocks it."

AVOID SAYING: Do not imply the system handles all future input types gracefully. Unknown values in some fields produce warnings, not hard rejects.

Q: 13. "Can CerbaSeal integrate with our existing audit / logging infrastructure?"

WHY SHE ASKS: Line Axia will have existing systems. They will want to know where CerbaSeal fits.

YOUR ANSWER: "Not out of the box — that is pilot-scoped integration work. CerbaSeal produces evidence bundles and a hash-linked audit log. Those can be exported and ingested into existing logging systems. The integration layer between CerbaSeal's output format and your infrastructure would be defined during scoping and would be part of the pilot scope definition."

AVOID SAYING: Do not imply pre-built integrations exist. They do not.

Q: 14. "How does CerbaSeal handle multi-workflow or multi-client scenarios?"

WHY SHE ASKS: If Line Axia wants to roll this out across multiple clients, they need to know the scalability story.

YOUR ANSWER: "Multi-client support is not yet implemented. The first pilot is explicitly one client, one workflow. Expanding to multiple workflows or clients is a next-phase discussion after a successful pilot. The architecture does not prevent it — but it has not been built or tested."

AVOID SAYING: Do not imply multi-client capability exists.

Q: 15. "What does a failed pilot look like, and what do we owe each other if that happens?"

WHY SHE ASKS: A smart CTO always asks about the failure scenario, not just the success case.

YOUR ANSWER: "If the pilot doesn't meet the agreed success criteria, you get a final findings report documenting what worked, what didn't, and why — with specific, bounded recommendations. You keep all artifacts. The agreement should specify: what 'failure' means, what each party owes, and whether there's any fee adjustment. I'd rather define that before we start than negotiate it at the end."

AVOID SAYING: Do not promise a refund policy you haven't agreed to.

Q: 16. "Is there a production roadmap? What does CerbaSeal look like in 12 months?"

WHY SHE ASKS: She's evaluating this as a long-term partnership, not a one-time experiment.

YOUR ANSWER: "There is a documented gap list — persistent storage, cryptographic signing, identity provider integration, third-party security review, multi-client support. Those are the building blocks for production. A 12-month roadmap would be shaped by what the pilot reveals. I'd rather commit to specific outcomes based on what we learn than over-promise on a schedule."

AVOID SAYING: Do not commit to a product roadmap you can't back up.

Q: 17. "What are the actual performance characteristics? How fast is the gate?"

WHY SHE ASKS: For production AI governance, latency matters. She will want to know the enforcement doesn't slow down decision loops.

YOUR ANSWER: "The test suite runs 372 tests in under 300 milliseconds. Single gate evaluations are sub-millisecond. There is no network call in the enforcement path. No load or stress testing has been done yet — that would be part of pre-production qualification. For a pilot evaluation context, performance is not the constraint."

AVOID SAYING: Do not claim production-validated performance numbers. Load testing has not been done.

Q: 18. "How do we know your documentation matches what the code actually does?"

WHY SHE ASKS: A technically sophisticated reviewer will be suspicious of documentation that looks too good.

YOUR ANSWER: "That is exactly what the 15 audit checks test. Several of those checks specifically verify that the documented claims appear in the portal, that the test count matches the actual run, that every invariant is linked to a covering test, and that no forbidden phrases appear. The documentation is not separate from the code — it is tested against it."

AVOID SAYING: Do not overclaim perfect documentation coverage. Some fields have nuances the docs don't fully capture.

Q: 19. "What happens if our client's AI system finds a way around CerbaSeal?"

WHY SHE ASKS: An adversarial question about bypass resistance. Critical for a governance tool.

YOUR ANSWER: "66 of our 372 tests are specifically designed to try to break or bypass the enforcement. The core protections are hard — AI cannot authorize its own requests, forged results are rejected by a cryptographic registry, unexpected errors fail closed. The weaker points are the caller-supplied fields: if the calling system lies about logging state or prohibited-use flags, CerbaSeal trusts those. That is a documented architectural dependency on upstream trustworthiness. For a controlled pilot it is manageable. For production it requires additional verification."

AVOID SAYING: Do not claim the system is bypass-proof. No system is, and the security brief says so.

Q: 20. "What would happen if one of our clients' regulators audited the system?"

WHY SHE ASKS: EU AI Act and financial regulation creates audit obligations. She needs to know the system is auditable.

YOUR ANSWER: "CerbaSeal is designed to be auditable — every decision has a reason code, an evidence bundle, and a verifiable chain of custody. What a regulator would not yet have is a third-party security review, cryptographic signatures on the evidence, or an official compliance certification. Those are the three things I'd want in place before a regulator looked at it. A pilot is the step before that."

AVOID SAYING: Do not claim regulatory compliance. It does not exist.

Q: 21. "What makes CerbaSeal different from what we could build ourselves?"

WHY SHE ASKS: Any well-resourced firm might consider building in-house rather than adopting external governance infrastructure.

YOUR ANSWER: "Build-vs-buy is a legitimate question. What you get with CerbaSeal: a governance layer that has been adversarially tested with 66 bypass attempts, a documented invariant model with 12 hard rules, an evidence and audit system, and a clear architectural boundary between enforcement and business logic. What you would need to build: all of that, from scratch, plus the test suite, plus the invariant model. The question is whether governance enforcement is core to what Line Axia builds or core to what you sell."

AVOID SAYING: Do not disparage in-house engineering. Make the case on merit.

Q: 22. "How do we handle a situation where CerbaSeal blocks something it should have allowed?"

WHY SHE ASKS: False positives in a governance system are operationally painful. She will want to know the exception path.

YOUR ANSWER: "Every HOLD and REJECT comes with a diagnostic report explaining exactly which rule was triggered. For a HOLD: a human reviewer reads the diagnostic, decides whether to approve, and the system logs that decision. For a REJECT that seems wrong: the issue goes into the tracked queue, root cause is investigated, and if the rule is wrong the fix is scoped and documented. No 'override' button. Everything is logged."

AVOID SAYING: Do not imply there is an easy bypass or admin override. There isn't — by design.

Q: 23. "Can you tell us more about the a16z application or any other partnerships you're in?"

WHY SHE ASKS: Potential conflict with an exclusivity arrangement. This is a strategic question, not a technical one.

YOUR ANSWER: Jesse answers this directly. Know your position before the call. If you are in active conversations with investors, that is relevant context for an exclusivity discussion.

AVOID SAYING: Do not get caught in an inconsistency about your current partnership conversations.

Q: 24. "What governing law would you want for the agreement?"

WHY SHE ASKS: France-based firm, EU clients — they will want EU or French law. Jesse needs to know his position.

YOUR ANSWER: Jesse answers this directly. Suggested framing: "I'm open to French law or EU law given your client base. The things I'd want to nail down regardless of jurisdiction: what constitutes a change request, evidence ownership, and liability cap. Those matter more to me than the governing law choice."

AVOID SAYING: Do not dismiss the jurisdiction question. It will be a sticking point for Tina Simpson.

Q: 25. "What would exclusivity actually mean, and what would it cost us?"

WHY SHE ASKS: If the conversation gets to 12-month EU exclusivity, she will want to understand what she's buying.

YOUR ANSWER: "EU exclusivity would mean I don't deploy CerbaSeal for another client in the EU for 12 months. What I'd want to define: what counts as 'EU' for this purpose, what event triggers the right of first refusal to extend, and what ends the exclusivity if the engagement is not active. The commercial value of exclusivity is a separate negotiation from the pilot fee — I'd rather not bundle them."

AVOID SAYING: Do not commit to exclusivity terms on the call. Get it in writing.

Read this the morning of the call. One page. Plain English. No technical jargon.

1. "Where is CerbaSeal / what is VeraSeal?"

SHORT ANSWER: "CerbaSeal is the system. VeraSeal doesn't exist in the codebase."

HONEST ANSWER: "What I have is a working enforcement engine, fully tested, not yet deployed outside a demo environment."

DANGER — DO NOT SAY: "VeraSeal is our..." — stop. Do not finish this sentence.

2. "Is this EU-deployable?"

SHORT ANSWER: "Yes architecturally — no external calls, no cloud, it runs wherever Node.js runs."

HONEST ANSWER: "I haven't done it yet. The first client deployment would be the first deployment anywhere."

DANGER — DO NOT SAY: "We've already tested this in EU environments." — you have not.

3. "What do you actually do during the pilot?"

SHORT ANSWER: "Heavy week one, then weekly 30-minute calls and email support."

HONEST ANSWER: "I'm a solo founder with a documented 48-hour self-service model. Beyond that, I don't have a backup."

DANGER — DO NOT SAY: "I'm available 24/7." — you are not.

4. "How available are you?"

SHORT ANSWER: "3–5 hours per week after week one, with defined response times for issues."

HONEST ANSWER: "Solo founder. If I'm unavailable the system runs without me for 48 hours. Beyond that is a risk I've been transparent about."

DANGER — DO NOT SAY: "Don't worry, I'll always be there." — do not promise what you cannot guarantee.

5. "Any open-source risks?"

SHORT ANSWER: "One runtime dependency, MIT licensed. No GPL anywhere in the tree."

HONEST ANSWER: "Five packages total in the deployment. All MIT. No copyleft. No external services."

DANGER — DO NOT SAY: "It's completely custom-built from scratch." — tsx is a dependency. Name it.

6. "What happens to the evidence log if the server restarts?"

SHORT ANSWER: "It's lost right now. Persistent storage is my top build priority before any pilot starts."

HONEST ANSWER: "This is a real gap. It must be fixed before client data touches the system."

DANGER — DO NOT SAY: "The evidence is fully durable." — it is not. In-memory means lost on restart.

7. "Has anyone else reviewed your security?"

SHORT ANSWER: "No external review yet. I have a security brief that documents every known limitation."

HONEST ANSWER: "All security review to date has been internal. External review is on the roadmap before production."

DANGER — DO NOT SAY: "We've been reviewed by..." — do not name anyone unless it is true.

8. "Is the audit chain cryptographically signed?"

SHORT ANSWER: "Hash-linked, not key-signed. Proves consistency. Doesn't prove origin."

HONEST ANSWER: "For legal-weight evidence, we would need HMAC signing. That's documented as a future requirement."

DANGER — DO NOT SAY: "The evidence is cryptographically verified." — it is hash-chained, not signed. Different thing.

9. "Do you have any existing clients?"

SHORT ANSWER: "No. This call is the beginning of that conversation."

HONEST ANSWER: "No signed pilot client. No commercial agreement. CerbaSeal is a proof-stage product."

DANGER — DO NOT SAY: "We're in conversations with several firms." — do not imply clients you don't have.

10. "Is CerbaSeal production-ready?"

SHORT ANSWER: "No. It's pilot-ready — controlled environment, one workflow, no production decisions."

HONEST ANSWER: "Production requires persistent storage, cryptographic signing, external security review, and a signed agreement. Those are the gaps."

DANGER — DO NOT SAY: "We're very close to production-ready." — you are not. Say what you are.

Test count: 372 passing, 0 failing — confirmed this morning with pnpm test

[Confirmed] Audit: 15/15 checks passing — confirmed with pnpm audit:repo

[Confirmed] LICENSE file exists — proprietary, Lamont Labs, all rights reserved

[Confirmed] Demo live at cerbaseal.replit.app — open it before the call

[Do Before Call] Know your position on: cyber liability insurance, governing law preference, exclusivity terms

[Do Before Call] Know your answer to: "how long to build persistent storage?" — estimate 2–5 days

[Do Before Call] Run through Section 8 questions in the CTO Review Pack verbally

[On The Call] If she says VeraSeal: correct it gently, move on, do not make it a moment

[On The Call] Lead with what is real. The enforcement core is real. The tests are real. The gap is real.

[On The Call] Do not overclaim. The claims you make will be checked. Make only ones you can defend.

[After The Call] Follow up in writing. Confirm the pilot shape, prerequisites, and next steps in an email.

CLOSING POSITION — The honest competitive advantage

The competitive position is not "we are production-ready." The competitive position is: we are honest about what we are, we have built the enforcement logic that most governance products only describe in slide decks, and we are ready to prove it in a controlled environment with defined success criteria. That is a stronger position than overclaiming. Olivia will test the claims. The ones above will hold.

